# Projet Transversale

## Introduction

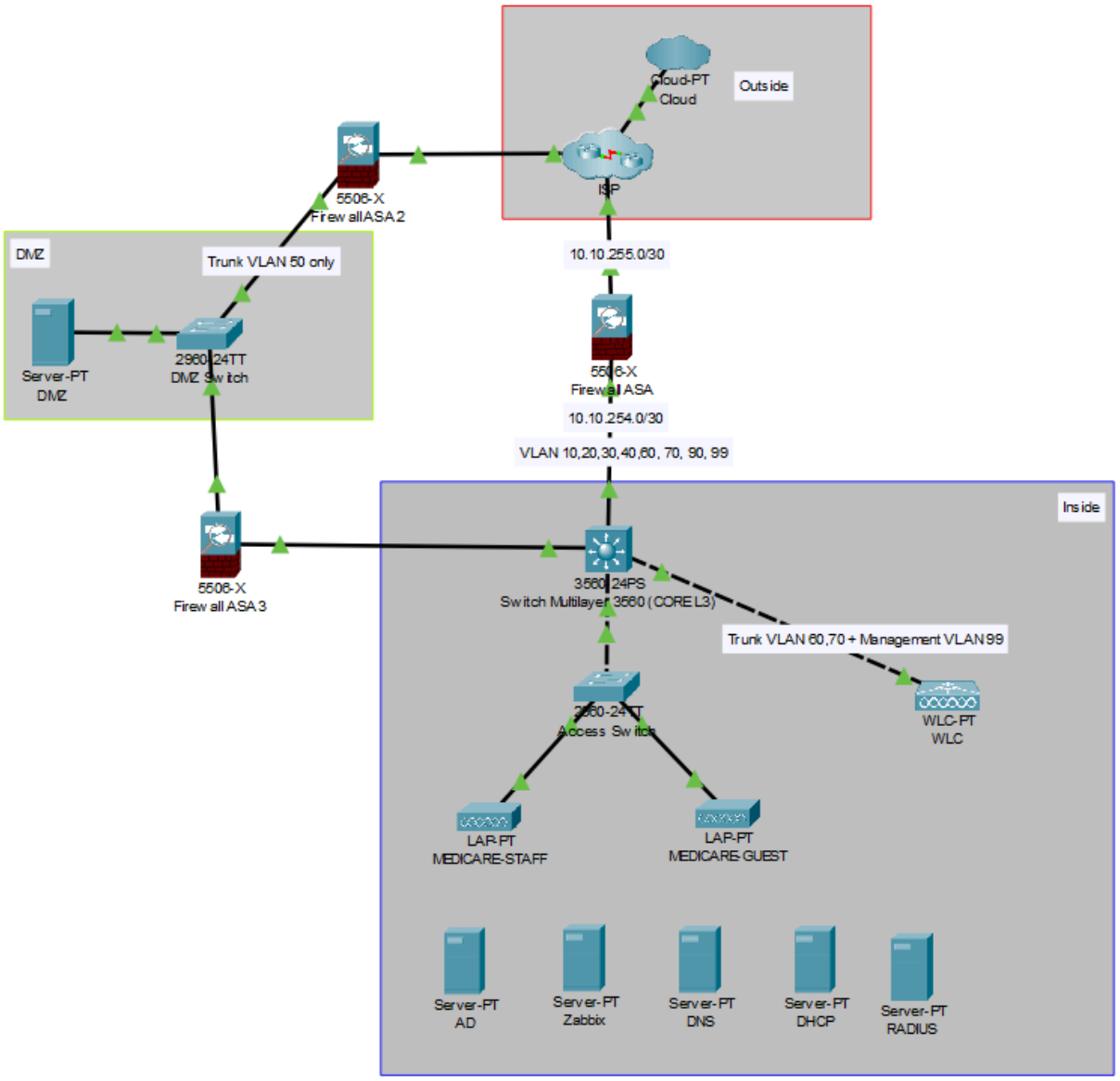
MediCare Solutions est une entreprise de télémédecine et santé, qui gère des données médicales sensibles (dossiers patients, diagnostics, historique, etc.). Dans ce contexte, je dois concevoir l'infrastructure IT de MediCare : serveurs, réseau, DMZ, Wi-Fi, accès distant, sauvegardes, etc… L'ensemble doit être dimensionné pour assurer services médicaux, confidentialité, disponibilité, télétravail, de garantir la sécurité, la disponibilité, la conformité et la scalabilité de l'infrastructure, pour que MediCare puisse opérer de façon fiable, même avec des contraintes réglementaires fortes, et accueillir les besoins futurs (augmentation d'utilisateurs, usage intensif, etc…)

Notre infrastructure doit donc tenir compte des risques associés au traitement de données de santé sensibles (cyberattaques, perte de données, indisponibilité, erreurs humaines, etc.), et prévoir des mesures de mitigation (redondance, sauvegarde, segmentation, contrôle d'accès, audits, etc.).

Je dois donc formaliser ce contexte, concevoir l'infrastructure, évaluer les risques (matrice risques), pour démontrer que l'architecture est sérieuse, robuste, conforme, et professionnellement viable

## Architecture réseau complète

### Schéma réseau complet dans Cisco Packet Tracer




# Plan d’adressage IPv4 (10.10.0.0/16) + IPv6 (ULA fd10:10::/48)

## VLANs (LAN + Wi-Fi)

> Règle simple : Gateway = .1 et IPv6 gateway = ::1 sur chaque VLAN.

- **VLAN 10 – MEDICAL (postes médecins/interne)**
  - IPv4: **10.10.10.0/23** (255.255.254.0) — GW **10.10.10.1**
  - IPv6: **fd10:10:10::/64** — GW **fd10:10:10::1**
  - DHCP: 10.10.10.50 → 10.10.11.250
- **VLAN 20 – ADMIN (RH/finance/admin)**

    - IPv4: **10.10.20.0/23** — GW **10.10.20.1**
    - IPv6: **fd10:10:20::/64** — GW **fd10:10:20::1**
    - DHCP: 10.10.20.50 → 10.10.21.250
- **VLAN 30 – IT (admin sys/réseau)**
    - IPv4: **10.10.30.0/24** — GW **10.10.30.1**
    - IPv6: **fd10:10:30::/64** — GW **fd10:10:30::1**
    - DHCP: 10.10.30.50 → 10.10.30.200
- **VLAN 40 – SERVERS (AD, Nextcloud, Zabbix, etc.)**
    - IPv4: **10.10.40.0/24** — GW **10.10.40.1**
    - IPv6: **fd10:10:40::/64** — GW **fd10:10:40::1**
    - IPs statiques (exemples ci-dessous)
- **VLAN 60 – WIFI-INTERNE (staff BYOD / laptops internes)**
    - IPv4: **10.10.60.0/22** — GW **10.10.60.1**
    - IPv6: **fd10:10:60::/64** — GW **fd10:10:60::1**
    - DHCP: 10.10.60.50 → 10.10.63.250
- **VLAN 70 – WIFI-PUBLIC (Guest)**
    - IPv4: **10.10.70.0/22** — GW **10.10.70.1**
    - IPv6: **fd10:10:70::/64** — GW **fd10:10:70::1**
    - DHCP: 10.10.70.50 → 10.10.73.250
    - Règle: **Internet ONLY** (bloqué vers réseaux internes)
- **VLAN 90 – IOT/PRINT (imprimantes, objets, équipements)**
    - IPv4: **10.10.90.0/24** — GW **10.10.90.1**
    - IPv6: **fd10:10:90::/64** — GW **fd10:10:90::1**
- **VLAN 99 – MGMT (switch/AP/WLC/administration réseau)**
    - IPv4: **10.10.99.0/24** — GW **10.10.99.1**
    - IPv6: **fd10:10:99::/64** — GW **fd10:10:99::1**
    - (Idéalement pas de DHCP ici / IP statiques)

## DMZ + VPN + Transits (liaisons)

- **DMZ (derrière le firewall) – VLAN 50**
  - IPv4: **10.10.50.0/24** — GW **10.10.50.1** (sur le firewall)
  - IPv6: **fd10:10:50::/64** — GW **fd10:10:50::1**
- **Pool VPN (clients télétravail)**
  - IPv4: **10.10.100.0/23** (attribué par le firewall/VPN)
  - IPv6: **fd10:10:100::/64**
- **Transit CORE ↔ FIREWALL**
  - IPv4: **10.10.254.0/30**
    - FW: **10.10.254.1** | CORE: **10.10.254.2**
  - IPv6: **fd10:10:254::/64**
    - FW: **fd10:10:254::1** | CORE: **fd10:10:254::2**
- **Transit FIREWALL ↔ ISP (lab Packet Tracer)**
  - IPv4: **10.10.255.0/30**
    - ISP: **10.10.255.1** | FW(outside): **10.10.255.2**
  - IPv6: **fd10:10:255::/64**

---

# IP statiques (serveurs clés – exemple)

Dans **VLAN 40 – SERVERS** (10.10.40.0/24) :

- **AD/DNS/DHCP**: 10.10.40.10 | fd10:10:40::10
- **Zabbix**: 10.10.40.40 | fd10:10:40::40
- **RADIUS (802.1X Wi-Fi interne)**: 10.10.40.50 | fd10:10:40::50
- **Nextcloud/stockage**: 10.10.40.20 | fd10:10:40::20

Dans **DMZ – VLAN 50** (10.10.50.0/24) :

- **Reverse Proxy (Nginx/HAProxy)**: 10.10.50.10 | fd10:10:50::10
- **Web App**: 10.10.50.20 | fd10:10:50::20
- **Bastion**: 10.10.50.30 | fd10:10:50::30

---

# Impératifs techniques

- Solution de sauvegarde chiffrée avec rétention légale (10 ans pour les données médicales)
- Système de monitoring et d'alertes en temps réel
- Serveur de messagerie sécurisé avec chiffrement end-to-end
- Espace de stockage collaboratif avec gestion fine des droits d'accès
- Infrastructure hybride : Windows Server pour l'AD, Linux pour les services web
- Accès sécurisé multi-facteurs (VPN + 2FA) pour le télétravail
- Segmentation réseau (DMZ, VLAN médicaux, VLAN administratif)
- Solution de virtualisation pour optimiser les ressources

# Raisons des choix technologiques

## *Windows Server 2025 — Rôles et fonctionnalités à activer*

### *A. Identité & annuaire (socle de l'infrastructure)*

**Active Directory Domain Services (AD DS)**

Assure la gestion centralisée des comptes, groupes, stratégies GPO, délégations et authentification.

**À faire :** installer **AD DS** puis promouvoir le serveur en contrôleur de domaine.

**DNS Server (intégré à AD)**

Indispensable au fonctionnement d'AD : résolution interne, enregistrements SRV, découverte des services.

**À faire :** créer la zone interne (ex. *medicare.local*), configurer des redirecteurs vers le firewall/ISP.

**Windows LAPS (recommandé en entreprise)**

Permet la rotation et la gestion sécurisée des mots de passe administrateurs locaux (y compris DSRM).

### *B. Adressage réseau*

**DHCP Server**

Distribue automatiquement les IP, DNS et passerelles selon les VLAN (VLAN10/20/60/70).

**À faire :** installer le rôle, autoriser le serveur dans l'AD, puis créer un scope par VLAN.

### *C. Authentification réseau (Wi-Fi Staff, VPN, filaire éventuelle)*

**NPS (Network Policy Server) — RADIUS**

Utilisé pour :

- l'authentification 802.1X (Wi-Fi staff),
- le VPN (ASA ou Windows RRAS),
- des règles basées sur les groupes AD.

**À faire :**

- créer les "RADIUS Clients" (WLC, ASA),
- créer des Network Policies (WiFi-STAFF, VPN-REMOTE),
- configurer EAP (idéalement EAP-TLS si tu disposes d'une PKI).

### *D. Stockage et partage de fichiers*

**File and Storage Services (SMB)**

Gestion des partages collaboratifs avec droits NTFS + groupes AD.

**Sécurité recommandée :**

- activer l'encryption SMB sur les partages sensibles (santé),
- désactiver SMB1.

**BitLocker**

Chiffre les volumes (OS, données) pour protéger les données au repos.

### *E. Accès à distance (optionnel si l'ASA gère déjà le VPN)*

**Remote Access / RRAS**

Serveur VPN (IKEv2, SSTP…) si tu ne passes pas par l'ASA.

**À faire :** définir le pool VPN (ex. 10.10.100.0/23), les protocoles et l'authentification NPS.

**RD Gateway**

Fournit un accès RDP sécurisé via HTTPS pour les administrateurs.

Recommandé derrière des ACL strictes.

**Architecture recommandée :**

- VPN géré par l'ASA pour les utilisateurs distants,
- Bastion (SSH/RDP via RD Gateway) pour les administrateurs.

---

### *2) Configuration DNS / DHCP / RADIUS (version projet)*

#### *A. DNS (sur le contrôleur de domaine)*

- Créer la zone AD (*medicare.local*).
- Ajouter les redirecteurs DNS externes.
- Définir les enregistrements utiles : *zabbix.medicare.local*, *nextcloud*, *vpn*, *proxy*, etc.

---

#### *B. DHCP (un scope par VLAN)*

Créer les scopes :

| VLAN | Nom | Adresse |
|---|---|---|
| VLAN10 | MEDICAL | 10.10.10.0/23 |
| VLAN20 | ADMIN | 10.10.20.0/23 |
| VLAN60 | WiFi-STAFF | 10.10.60.0/22 |
| VLAN70 | WiFi-GUEST | 10.10.70.0/22 |

**Options standard :**

- *003 Router* = SVI du VLAN (ex. 10.10.10.1)
- *006 DNS Server* = 10.10.40.10 (DC)
- *015 DNS Domain Name* = medicare.local

---

#### *C. NPS / RADIUS*

**RADIUS Clients à ajouter**

- WLC (IP management en VLAN99)
- ASA (interface inside ou transit)

**Policies :**

1. **WiFi-STAFF 802.1X**
   - Groupe AD : WIFI-STAFF
   - EAP-TLS si PKI, sinon PEAP/MSCHAPv2 pour un projet.
2. **VPN-REMOTE**

- Groupe AD : VPN-USERS
- (Option) contraintes horaires / posture.

**Wi-Fi Guest**

- Pas de RADIUS.
- VLAN70 isolé + accès internet-only via firewall.

---

## *Zabbix 7.4 — Paramètres essentiels*

### *A. Chiffrement (TLS)*

Activer TLS entre :

- Zabbix Server ↔ Agents,
- Frontend ↔ Server,
- Proxys ↔ Server.

Certificats ou PSK selon le niveau de production.

---

### *B. Supervision à mettre en place*

- Serveurs Windows (AD, DNS, DHCP, NPS, fichiers).
- Serveurs Linux (Zabbix, Web, Nextcloud, Reverse Proxy).
- Équipements réseau (ASA, switch core, WLC) via SNMP.

---

### *C. Découverte & automatisation*

- LLD pour filesystem, services, interfaces.
- Network Discovery (optionnel) pour auto-enregistrer des hôtes.

---

### *D. Alerting avancé*

Configurer :

- Media Types : email, webhook, etc.
- Actions : escalades, triggers.

Triggers recommandés :

- indisponibilité de services,
- surcharge CPU/RAM,

- bascule interface ASA,
- “VPN down”,
- “Web DMZ down”, etc.

---

### *4) Stockage + synchronisation rsync + sauvegarde*

#### *A. Stockage collaboratif interne*

Deux possibilités :

**1. Windows File Server (SMB)**

- Gestion des droits via groupes AD.
- SMB encryption pour données sensibles.

**2. Nextcloud (Linux) + LDAP/AD**

Solution plus orientée collaboration (partage, fichiers, journalisation).

---

#### *B. Synchronisation / sauvegarde via rsync*

Utiliser rsync **sur SSH** pour garantir le chiffrement.

**Exemple de stratégie :**

- **Toutes les heures :** synchronisation rsync incrémentale.
- **Chaque nuit :** snapshot (LVM/ZFS/Btrfs).
- **Rétention longue :** archivage mensuel + copie offsite.

> rsync = synchro ; pour de la rétention 10 ans → documenter une stratégie d’archivage (snapshots + duplication distante).

---

### *5) Accès distant + chiffrement*

**Télétravail**

- VPN (ASA ou RRAS)
- MFA (obligatoire dans un contexte santé)

**Administration**

- Bastion en DMZ
- Accès restreint (seulement VLAN30 / IT)

**Chiffrement**

- **Au repos :** BitLocker
- **En transit :** TLS (web), SMB Encryption, VPN, Zabbix TLS, SSH, etc.

---

# Architecture de sécurité

# Cadre réglementaire et Matrice de Risque

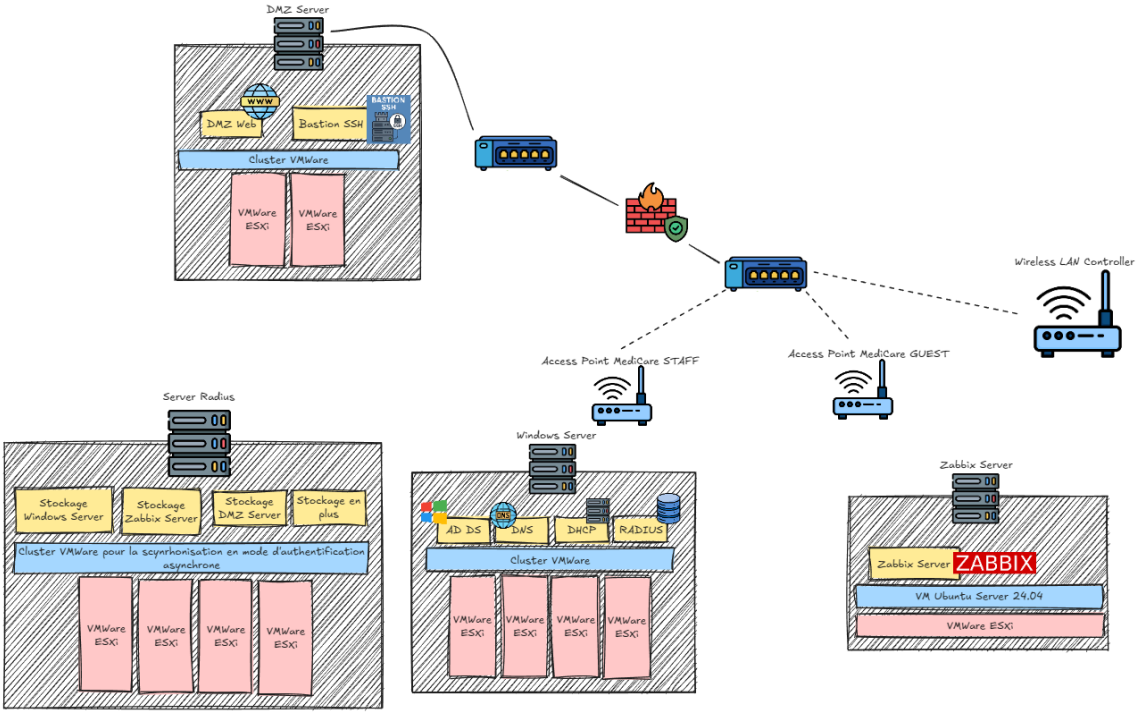
## Cadre réglementaire

Quand une organisation en France héberge ou traite des **données de santé à caractère personnel**, plusieurs réglementations et cadres s'appliquent :

- RGPD (Règlement Général sur la Protection des Données) : c'est le cadre européen général de protection des données personnelles. Les données de santé sont considérées comme « sensibles », ce qui implique des obligations renforcées (consentement, droit des personnes, sécurisation, minimisation, notification des violations, …
- En complément, en France il y a la HDS (Hébergement de Données de Santé) — certification obligatoire pour tout hébergement de données de santé.
- Le cadre HDS impose des exigences strictes : infrastructure sécurisée, chiffrement, contrôle d'accès, traçabilité, sauvegardes, continuité de service, sécurité physique et logique, etc..
- L'article du code de la santé publique (notamment L.1111-8) rend obligatoire l'usage d'un hébergeur certifié HDS quand on héberge des données de santé.
- De plus, toute structure manipulant ces données doit respecter les principes du RGPD : minimisation, consentement, droit d'accès, sécurisation, traçabilité, notification en cas de violation...

L'infrastructure MediCare **doit** respecter ce double cadre, RGPD et HDS, ce qui fixe le **socle de sécurité** et le **niveau d'exigence** pour le design (sécurité, segmentation, sauvegardes, accès, journalisation, etc.).

## Services à monter dans l’infrastructure




- **Je vais mettre en place l'architecture réseau complète de MediCare au sein d'un environnement virtualisé et organisé en zones fonctionnelles (Inside, DMZ, Outside) sur une machine Serveur AD avec un ESXI.**

  La partie interne (Inside) sera hébergée dans notre datacenter et reposera sur un **switch cœur de réseau Layer 3 (Cisco 3560)** chargé d'assurer le routage inter-VLAN.

  J'y définirai une **infrastructure segmentée** à l'aide de VLAN (Medical, Admin, IT, Servers, WiFi-Staff, WiFi-Guest, Management)

- Le reverse proxy et portail web seront mis en place sur le serveur DMZ tout en préservant l'intégrité du réseau interne.

- Sur le **serveur Windows**, je mettrai en place les rôles d'**Active Directory Domain Services, DNS, DHCP, NPS (RADIUS)** ainsi que le **serveur de fichiers sécurisé**.

- **La DMZ sera construite conformément au schéma**, en connectant le firewall ASA à un **switch DMZ** isolé.

  Cette zone accueillera les services exposés vers l'extérieur (web, API, proxy), hébergés sur des VMs Linux dédiées (conteneurisation).

  Le firewall ASA sera configuré avec des **règles strictes**, du **NAT**, des ACL limitant les flux, et une inspection avancée afin d'empêcher toute intrusion dans le réseau interne.

- **Pour la supervision et la traçabilité**, je mettrai en place une solution complète avec le serveur Zabbix.

Tous les équipements du réseau (ASA, WLC, switches, serveurs Windows/Linux) seront intégrés via agents ou SNMP afin de permettre :

- la détection des pannes,
- la surveillance en temps réel,
- l'envoi d'alertes,
- la collecte de journaux conforme aux exigences HDS/RGPD.

- **Je déploierai un système de sauvegarde chiffrée**, reposant sur rsync sécurisé (SSH) pour la synchronisation sur le serveur de stockage (RADIUS) et l'infrastructure de backup.

  Des snapshots quotidiens et des archives mensuelles seront générés avec une **rétention longue (10 ans)**, conformément aux obligations liées aux données de santé.

  Les stratégies de sauvegarde engloberont les fichiers patients, les bases de données, les configurations réseau, les VMs et les journaux.

- **Afin de garantir la confidentialité et l'intégrité des données**, je mettrai en place plusieurs niveaux de chiffrement :
  - BitLocker sur Windows Server,
  - LUKS sur les serveurs Linux,
  - TLS 1.2/1.3 pour toutes les communications,
  - SMB Encryption pour les partages internes,
  - VPN chiffré (IKEv2) pour les accès distants du personnel médical.

  Le chiffrement sera obligatoire aussi bien pour les données en transit que pour les données au repos.

- **Un système ACL strict sera instauré grâce au serveur Windows**, basé sur l'authentification forte (MFA), les groupes Active Directory, les policies RADIUS, et la séparation claire des privilèges entre :
  - administrateurs réseau,
  - administrateurs systèmes,
  - support technique,
  - personnel médical,
  - DPO (Data Protection Officer).

Cela permettra de limiter les risques d’erreur humaine ou intrusion interne.

- **Le Wi-Fi sera séparé en deux infrastructures distinctes** :
  - **Wi-Fi Staff (VLAN 60)** : sécurisé via WPA2-Enterprise et authentification 802.1X via NPS/RADIUS.
  - **Wi-Fi Guest (VLAN 70)** : réseau isolé sans accès au LAN interne, strictement limité à Internet via des ACL sur l’ASA.

    Le WLC orchestrera les points d’accès (LAP), et le trunk VLAN entre le CORE et le WLC transportera les réseaux Wi-Fi et le réseau de management.
- **Un accès VPN sécurisé avec MFA sera mis en œuvre**, permettant au personnel médical et administratif de se connecter à distance aux ressources internes tout en appliquant un contrôle d’accès strict basé sur les politiques RADIUS et les groupes AD.
- **Un pare-feu de nouvelle génération (ASA) sera configuré avec des mécanismes de filtrage, IDS/IPS, NAT, ACL et inspection profonde**, garantissant l’isolation des zones sensibles et la protection du réseau interne.

  La segmentation entre LAN, DMZ, serveurs, Wi-Fi staff et guest permettra de réduire la surface d’attaque et de répondre aux exigences HDS.
- **Enfin, j’établirai toute la documentation de gestion opérationnelle**, incluant :
  - les procédures de sauvegarde,
  - le PRA/PCA,
  - les processus d’escalade,
  - les procédures d’incident et de restauration,
  - la documentation réseau (plans, configurations, VLAN, routage),
  - la gouvernance incluant le rôle du DPO.

    Cette étape garantira la conformité réglementaire et la lisibilité de l’infrastructure pour les équipes futures.

## Matrice de Risque

Brouillon

| # | Risque / Menace | Probabilité (P) [1–5] | Gravité / Impact (G) [1–5] | Score (P×G) |
|---|---|---|---|---|
| 1 | Cyberattaque / ransomware sur | 4 | 5 | 20 |

| # | Risque / Menace | Probabilité (P) [1–5] | Gravité / Impact (G) [1–5] | Score (P×G) |
|---|---|---|---|---|
| | serveurs médicaux | | | |
| 2 | Intrusion via Wi-Fi public (Guest) | 3 | 5 | 15 |
| 3 | Compromission d’un compte administrateur (Windows / Linux) | 3 | 5 | 15 |
| 4 | Faille zero-day sur le firewall / ASA | 2 | 5 | 10 |
| 5 | Mauvaise configuration VPN → accès non autorisé | 3 | 5 | 15 |
| 6 | Fuite de données sensibles (PHI – patients) | 2 | 5 | 10 |
| 7 | Panne du firewall / ASA (point unique) | 2 | 5 | 10 |
| 8 | Panne du switch CORE (3560) | 2 | 5 | 10 |
| 9 | Panne serveur AD / DNS / DHCP (service critique) | 3 | 4 | 12 |
| 10 | Panne serveur RADIUS (auth Wi-Fi interne) | 3 | 4 | 12 |
| 11 | Mauvaise configuration VLAN / ACL → fuite réseau interne / DMZ / Wi-Fi | 3 | 5 | 15 |
| 12 | Erreur humaine — mauvaise manipulation | 3 | 5 | 15 |

| # | Risque / Menace | Probabilité (P) [1–5] | Gravité / Impact (G) [1–5] | Score (P×G) |
|---|---|---|---|---|
| | (firewall, AD, ACL…) | | | |
| 13 | Panne de stockage (RAID, disque dur) sur un serveur important | 3 | 3 | 9 |
| 14 | Perte / corruption des sauvegardes (backup) | 2 | 5 | 10 |
| 15 | Non-conformité réglementaire (RGPD / HDS) | 2 | 5 | 10 |
| 16 | Non-respect des obligations de journalisation / traçabilité | 2 | 4 | 8 |
| 17 | Indisponibilité du fournisseur Internet (ISP) | 3 | 4 | 12 |
| 18 | Evolution du nombre d’utilisateurs + surcharge non anticipée | 4 | 3 | 12 |
| 19 | Saturation du réseau / bande passante insuffisante | 3 | 3 | 9 |
| 20 | Incident critique sur base de données patients | 2 | 5 | 10 |

# Budget prévisionnel (CAPEX/OPEX)

| Poste | Description | CAPEX (€) | OPEX annuel (€) |
|---|---|---|---|
| **Serveur physique** | Remplacement de l'ancien serveur (ESXi compatible, 2 CPU, 128Go | 6 000 | - |

| Poste | Description | CAPEX (€) | OPEX annuel (€) |
|---|---|---|---|
| | RAM, RAID) | | |
| **Stockage NAS** | NAS Synology 8 baies + 8x HDD 4To RAID 6 | 2 500 | - |
| **Cloud Backup (hybride)** | Stockage type Backblaze B2 (2To) | - | 240 |
| **Switch manageable (PoE)** | Pour gestion des VLANs | 600 | - |
| **Firewall pfSense** | Appliance ou mini-PC dédié (fanless) | 300 | - |
| **UPS (Onduleur)** | Protection serveur + NAS | 400 | - |
| **Licence Windows Server** | AD + rôles de base (1 licence Standard) | 800 | - |
| **Infrastructure réseau (câblage, baies)** | Mise à niveau + brassage | 600 | - |
| **Divers (rack, connecteurs, etc.)** | Matériel divers | 300 | - |
| **Coût de maintenance constructeur** | Contrat 3 ans pour le serveur physique | - | 300 |
| **Énergie / électricité** | Estimation consommation 24/7 (500W) | - | 600 |
| **Total** | | **11 500 €** | **1 140 €/an** |

# Plan de reprise d'activité (PRA) et plan de continuité d'activité (PCA)

## Objectifs

- **RTO** (Recovery Time Objective) : < 1 heure

| Élément | Détail |
|---|---|
| **Sauvegardes locales** | Rsync horaire sur NAS + snapshot complet chaque nuit |
| **Stockage cloud** | Réplication chiffrée quotidienne des données critiques (Cloud) |

| Élément | Détail |
| --- | --- |
| **Procédures** | Script de restauration automatique des VMs et données sur ESXi |
| **Tests** | Simulation de restauration chaque trimestre |
| **Documentation** | Cahier de procédures PRA à jour (stocké sur papier + cloud sécurisé) |

- **RPO** (Recovery Point Objective) : 1 heure (grâce aux snapshots + Rsync)

| Élément | Détail |
| --- | --- |
| **Single server** | En cas de panne, redéploiement via image sur serveur de secours local |
| **VM redondantes** | Clonage régulier pour relance rapide |
| **Accès VPN** | Reconfiguration VPN via backup pfSense et redéploiement en 30 minutes |
| **Serveur secondaire ?** | Pas prévu à ce stade (risque : indispo temporaire si serveur HS) |

# Matrice RACI et planning de déploiement

## Matrice RACI

**Qui se chargera des tâches** : le groupe IT

**Qui approuve les tâches** : Le chef de projet de MediCare Solutions

**Celui qui est consulté** : Certains medecins de MediCare Solutions pour des tests

**Celui qui doit être informé** : Le chef de projet de MediCare Solutions

# Une document d’exploitation propre